



Lab 05: User Authentication - Identity-Aware Proxy

Cloud Security Fundamentals | GSP499

Overview

Built a Python web app on App Engine then used IAP to restrict access, retrieve user identity from request headers, and cryptographically verify that identity to prevent spoofing.

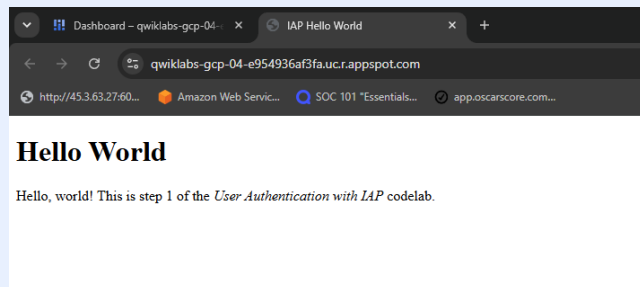
Objectives

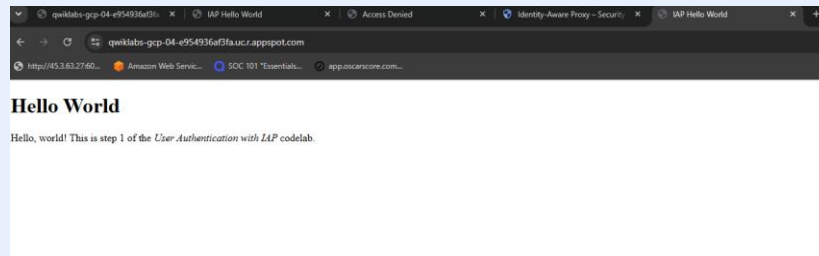
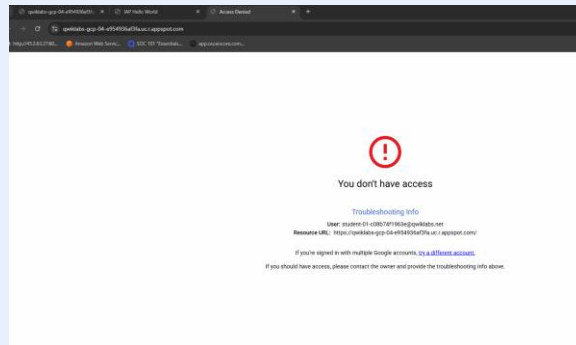
- Deploy a Python App Engine web application
- Restrict access using IAP
- Retrieve user identity from IAP request headers
- Cryptographically verify IAP identity to prevent spoofing

Task 1 - Deploy App and Protect with IAP

```
sed -i 's/python37/python313/g' app.yaml  
gcloud app deploy  
gcloud app browse
```

Then enabled IAP via Security → Identity-Aware Proxy, configured OAuth consent screen, and added student account as IAP-Secured Web App User.





Task 2 - Access User Identity Information

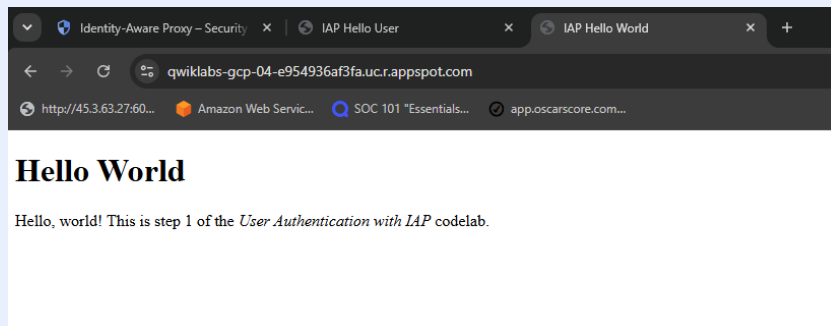
Updated app to read IAP-provided headers and display user email and ID.

- X-Goog-Authenticated-User-Email: contains verified user email
- X-Goog-Authenticated-User-ID: contains persistent unique user ID

```
user_email = request.headers.get('X-Goog-Authenticated-User-Email')
user_id = request.headers.get('X-Goog-Authenticated-User-ID')
```

Turning off IAP shows no user info. Sending a fake header via curl shows spoofing is possible without cryptographic verification.

```
curl -X GET [URL] -H "X-Goog-Authenticated-User-Email: totally fake email"
```

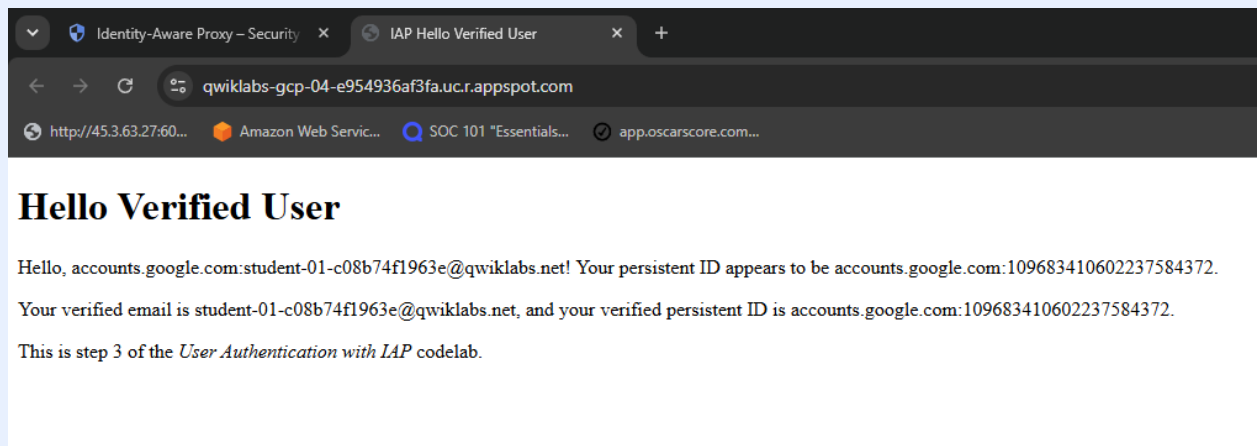


```
d-User-Email: totally fake email"
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
   Dload  Upload  Total   Spent    Left     Speed
100    36    100    36      0      0    315      0 --:--:-- --:--:-- --:--:--    315
```

Task 3 - Cryptographic Verification

Added auth.py to verify the X-Goog-IAP-JWT-Assertion header using Google public keys. This prevents spoofing even if IAP is disabled or bypassed.

```
assertion = request.headers.get('X-Goog-IAP-JWT-Assertion')
info = jwt.decode(assertion, keys(), algorithms=['ES256'], audience=audience())
```



What I Learned

- IAP intercepts requests and authenticates users before they reach the app
- IAP adds X-Goog-Authenticated-User headers to every request it passes through
- Without IAP these headers can be spoofed by anyone sending a request
- Cryptographic verification using JWT ensures the identity came from IAP
- The X-Goog-IAP-JWT-Assertion header contains a Google-signed JWT token

Resources

GCP IAP Docs: <https://cloud.google.com/iap/docs>

Lab ID: GSP499